Penetration Testing Report Template

Student Assessment Template

Student Name	[Insert your name]
Student ID	23249815
Unit	ISEC6005
Assessment Title	Final Exam Part 2 - Report
Target Machine	[Insert target Name/IP]
Date Submitted	[Insert date]

Important: This report must present findings responsibly. Include only authorised testing activity, clear evidence, impact, and remediation. Long command histories should be moved to the appendix.

REMINDER – what to put here (from the boxes you practised): Use this for an FTP + HTTP box (like Viren – Windows / Microsoft ftpd). FIRST FLAG: anonymous FTP read. SECOND FLAG: pivot to the web service – files from FTP (e.g. a .htpasswd credential, or a writable web folder) let you reach a web shell, then run commands with curl. [TARGET-IP] = box IP; [WEB-PORT] = the HTTP port from nmap; [SHELL] = the web-shell page; [USER] = the account you land as (e.g. viren\rhea). KEY TIP: encode spaces in curl with -G --data-urlencode "cmd=...", or the URL truncates and only the first word runs.

Report Sections

1. Executive Summary
2. Scope and Rules of Engagement
3. Testing Methodology
4. Summary of Findings
5. Detailed Findings
6. Attack Path Summary
7. Remediation Plan
8. Conclusion
9. Appendix A. Technical Evidence
10. Appendix B. References

1. Executive Summary

During the authorised assessment of the target host ([TARGET-IP]), the FTP service on port 21 was found to permit anonymous access. An unauthenticated attacker could log in with the username 'anonymous' and no valid password and read files stored on the server, including a file containing the flag and material that enabled access to the web service (for example a credential file or a writable web directory). Using this, a web shell on the HTTP service (port [WEB-PORT]) was reached and used to execute operating-system commands – confirmed with curl – giving code execution as [USER] and a second, higher-privilege flag. The highest risk is the resulting remote code execution (rated High). The main attack path is: anonymous FTP read → pivot to the web

service → web shell → command execution. The primary root cause is an FTP service that trusts unauthenticated users, combined with a reachable web shell.

Area	Student Entry	Guidance
Overall Risk	High	Choose one overall rating and justify it briefly.
Main Impact	An unauthenticated attacker can read files over anonymous FTP and use that foothold to reach a web shell on the HTTP service, gaining command execution on the host.	Describe what could happen to the system or organisation.
Primary Root Cause	Security misconfiguration – anonymous FTP access combined with a reachable web shell on the web service.	Example: misconfiguration, weak access control, exposed credentials.
Top Remediation Priority	Disable anonymous FTP access.	State what should be fixed first and why.

2. Scope and Rules of Engagement

2.1 Scope

Asset / Host	IP / URL	Service(s)	In Scope?
[TARGET-HOST e.g. Viren]	[TARGET-IP]	FTP (21)	Yes
[TARGET-HOST e.g. Viren]	[TARGET-IP]	HTTP ([WEB-PORT])	Yes

2.2 Rules of Engagement

- ☐ Testing was conducted only against authorised targets.
- ☐ Testing avoided unnecessary service disruption.
- ☐ Evidence was recorded for each finding.
- ☐ Sensitive data was handled responsibly and not disclosed unnecessarily.
- ☐ No persistence was installed unless explicitly required by the lab instructions.

3. Testing Methodology

Phase	Purpose	Evidence to Include
Reconnaissance	Confirm FTP (21) and the web service (HTTP) are running; identify the OS.	`nmap -p- -sV [TARGET-IP]` (confirm FTP 21 + web port [WEB-PORT])
Enumeration	Log in anonymously and list all	`ftp [TARGET-IP] -> login`

	files; browse/enumerate the web service.	`anonymous ; ls -la ; gobuster dir on the web service`
Vulnerability Analysis	Confirm anonymous FTP, and find what it gives you for the web (creds/writable dir).	`Anonymous login accepted (230); FTP files expose creds / a writable web folder`
Exploitation / Validation	Read the FTP files to get the flag and the web foothold.	`get [FILE] ; cat [FILE] (read flag + web foothold, e.g. a .htpasswd credential)`
Privilege Escalation	Reach a web shell and run commands with curl (encode spaces).	`curl -G "http://[TARGET-IP]:[WEB-PORT]/[SHELL]" --data-urlencode "cmd=whoami" -> [USER]`
Remediation Advice	Explain how to disable anonymous FTP + remove the web shell, and verify.	`disable anonymous FTP ; remove the web shell ; SFTP/FTPS ; least privilege`

4. Summary of Findings

ID	Finding	Risk	Affected Asset	Status
F-01	Anonymous FTP Access & Sensitive Data Exposure	High	[TARGET-IP] (FTP)	Open
F-02	Remote Code Execution via Web Shell (pivot from FTP)	High	[TARGET-IP] ([WEB-PORT])	Open

REMINDER (Summary of Findings): Example for this box: F-01 = Anonymous FTP Access & Sensitive Data Exposure (High). Add F-02 = Remote Code Execution via Web Shell (pivot from FTP) only if you also reached the intermediate flag; delete the unused F-03–F-05 rows.

5. Detailed Findings

REMINDER (Detailed Findings): Example for this box: Finding 1 = Anonymous FTP Access & Sensitive Data Exposure. Replace the Evidence block with YOUR own command output / screenshots. Keep Finding 2 (Remote Code Execution via Web Shell (pivot from FTP)) only if you reached the intermediate flag by reusing credentials – otherwise delete it.

Finding 1: Anonymous FTP Access & Sensitive Data Exposure

Risk Rating	High
Affected Asset(s)	[TARGET-IP], FTP service (port 21)
Vulnerability Type	Security misconfiguration – anonymous access (broken access control)
Evidence Reference	E-01, E-02
Business Impact	An attacker can read all files served over FTP, including credentials.
Remediation Priority	Immediate

Description

The FTP service on port 21 accepts the built-in 'anonymous' account with any or no password. Once logged in, the server's files were readable without authorisation, including a file that disclosed credentials and a file containing the flag. The weakness is that anonymous login was left enabled and sensitive files were stored in the FTP root, so the data is protected by obscurity rather than authentication. (On exam day, change [TARGET-IP] and the file names to what you find – the explanation of the weakness stays the same.)

Evidence

```
nmap -p21 -sV [TARGET-IP]              # confirm FTP service + version
ftp [TARGET-IP]                        # Name: anonymous  Password: (blank) -> 230
ftp> ls -la                            # list files (note hidden files)
ftp> get [FILE]                        # download the sensitive file
cat [FILE]                             # -> credentials / flag
```

Impact

Every file in the FTP tree is readable – not only the flag but configuration, backups and, as here, a credential file. The disclosed credentials provided authenticated access to another service, turning an information-disclosure issue into interactive access and lateral movement. In business terms this is unauthorised disclosure of confidential data and a foothold for deeper compromise.

Recommendation

Disable anonymous FTP; require authenticated, least-privilege accounts; replace plain FTP with FTPS or SFTP so credentials and data are encrypted in transit; remove sensitive files from the FTP root; and set directories read-only unless write access is genuinely required.

Verification After Fix

Re-attempt the anonymous login – it should be rejected with '530 Login incorrect' – and confirm the sensitive files are no longer retrievable without valid credentials.

Finding 2: Remote Code Execution via Web Shell (pivot from FTP)

Risk Rating	High
Affected Asset(s)	[TARGET-IP], HTTP service (port [WEB-PORT])
Vulnerability Type	Remote code execution via web shell
Evidence Reference	E-03
Business Impact	An attacker can run operating-system commands on the host as [USER].
Remediation Priority	Immediate

Description

Material obtained over anonymous FTP enabled access to the web service on port [WEB-PORT]. For example, a credential file (such as a .htpasswd protecting a directory) was read over FTP and cracked, or a web directory was writable, which allowed a web shell to be reached. Requesting that web shell and passing a command ran it on the server, confirmed with curl, giving command execution as [USER]. The weakness is an unauthenticated foothold from FTP combined with a reachable web shell on the HTTP service. (On exam day, change [WEB-PORT], [SHELL] and [USER]; the method stays the same.)

Evidence

```
# (if a .htpasswd credential was found over FTP) crack it:
hashcat -m 1600 htpasswd.hash rockyou.txt      # $apr1$ -> [PASSWORD]  (e.g. webgate:letmein)
# reach the web shell and run commands — ENCODE SPACES or the URL truncates:
curl -G "http://[TARGET-IP]:[WEB-PORT]/[SHELL]" --data-urlencode "cmd=whoami"            # ->
[USER] e.g. viren\rhea
curl -G "http://[TARGET-IP]:[WEB-PORT]/[SHELL]" --data-urlencode "cmd=type C:\Users\[USER]\
Desktop\flag.txt"
```

Impact

Reaching a web shell gives arbitrary command execution on the host as [USER] – the attacker can read any file the account can access (including the higher-privilege flag), run tools, and attempt further escalation. A simple information-disclosure foothold over FTP became full interactive control of the web server.

Recommendation

Remove the web shell and any upload/write exposure on the web root; disable anonymous FTP so the foothold is not available; store no credentials or web content on the FTP service; add input validation and least-privilege on the web application; and rotate any credentials (e.g. .htpasswd) that were disclosed.

Verification After Fix

Request the web-shell path – it should return 404/403 – and confirm the command parameter no longer executes; confirm anonymous FTP is rejected and the cracked credential no longer works.

6. Attack Path Summary

Step	Evidence	Security Meaning
Initial access / foothold	ftp [TARGET-IP] (login anonymous)	Anonymous login granted read access to the server's files with no credentials.

Local enumeration	ls -la ; get [FILE]	Reading the files revealed the flag and a foothold for the web service (e.g. a .htpasswd credential).
Credential or configuration weakness	hashcat -m 1600 htpasswd.hash rockyou.txt	Cracked the web credential found over FTP (apr1 hash).
Service or application abuse	curl -G "http://[TARGET-IP]:[WEB-PORT]/[SHELL]" --data-urlencode "cmd=whoami"	Reached the web shell and ran a command – returned [USER], confirming RCE.
Privilege escalation proof	curl ... --data-urlencode "cmd=type ...flag.txt"	Ran a command to read the higher-privilege flag.
Final impact	–	Command execution on the host obtained from an anonymous FTP foothold.

Attack Path Diagram

Anonymous FTP read → web foothold (credential / writable dir) → reach web shell → curl ?cmd= runs commands as [USER] → flag read.

7. Remediation Plan

Priority	Finding ID	Recommended Action	Owner	Verification Method
Immediate	F-01	Disable anonymous FTP and remove sensitive files from the FTP root.	Infrastructure team	Re-test that the anonymous login is rejected (530).
Immediate	F-02	Remove the web shell / fix the writable web directory; rotate any credentials disclosed over FTP (e.g. .htpasswd).	Web/ Infrastructure team	Confirm the web-shell path returns 404 and commands no longer run.
Long-term	–	Move to SFTP/FTPS, add input validation and least-privilege on the web app, and	Security team	Periodic configuration and code review.

		monitor FTP/web access logs.		

8. Conclusion

The assessment confirmed and fully validated an attack path from anonymous FTP access to remote code execution on the web service. The FTP exposure provided the foothold and a reachable web shell turned it into command execution as [USER]. Both are remediable by disabling anonymous access and removing the web shell. All testing stayed within the authorised scope and no data was altered or destroyed.

Appendix A. Technical Evidence

Use this appendix for detailed command output, screenshots, and supporting notes. Keep the main report concise.

Evidence ID	Command / Source	Screenshot / Output	Purpose
E-01	nmap -p- -sV [TARGET-IP]	[screenshot]	Confirms the FTP service and the web service/port.
E-02	ftp [TARGET-IP] ; ls -la ; get [FILE]	[screenshot]	Shows anonymous read access and the file giving the web foothold.
E-03	curl -G "http://[TARGET-IP]:[WEB-PORT]/[SHELL]" --data-urlencode "cmd=whoami"	[screenshot]	Shows command execution on the host (RCE) as [USER].

Appendix B. References

OWASP Web Security Testing Guide – FTP testing and file-upload / web-shell testing; OWASP Top 10 A03 Injection and A05 Security Misconfiguration; vendor documentation on disabling anonymous FTP and using FTPS/SFTP.

Student Submission Checklist

- ☐ Executive summary is written for a non-technical reader.
- ☐ Each finding includes risk, evidence, impact, and remediation.
- ☐ Screenshots are labelled and referenced in the text.
- ☐ Only authorised testing activity is included.
- ☐ Sensitive credentials are redacted unless required by assessment instructions.
- ☐ The final report is professional, concise, and free of unnecessary terminal history.